Case Study: Eir Laptop Encryption Vulnerability and Breach (August 2018)

1. Specific Aspect of GDPR Addressed

This case study relates to Article 32 (Security of processing) of the GDPR, which requires data controllers to ensure the implementation of appropriate technical and organisational measures to protect the privacy of personal data, for example, full disk encryption (Data Protection Commission, 2019). This case study also relates to Articles 33 (Notification of a personal data breach to the supervisory authority) and 34 (Communication of a personal data breach to the data subject). In August 2018, the telecommunications company Eir had a system misconfiguration that led to the standard encryption of 1,484 corporate laptops being removed, leading to the theft of an unencrypted device. This device contained the personal information (name, email address, mobile number and account number) of 36,642 Eir customers and 177 staff members (Data Protection Commission, 2018).

2. Resolution of the Incident

On 10 August 2018, Eir sent a breach notification to the Irish Data Protection Commission (DPC) (Data Protection Commission, 2018), in compliance with the legal requirements of mandatory reporting. Eir then implemented swift corrective measures: encryption was applied to the remaining 1,438 laptops within days, personal notifications were sent to affected individuals via Eir's contact details, and regular status reports were provided to the DPC during the monitoring period (Data Protection Commission, 2018; eircom Holdings, 2019).

3. Mitigation Steps as an Information Security Manager

To mitigate similar risks in the enterprise, as an Information Security Manager, I would implement the following 3 mitigations:

Ensure that Mobile Device Management (MDM) software is deployed on all devices to prevent users from disabling full disk encryption or changing encryption policies. MDM can be used to ensure that encryption cannot be bypassed (Data Protection Commission, 2019).

Conduct automated compliance audits daily across all mobile devices to instantly spot any unencrypted hardware.

Implement Data Loss Prevention (DLP) controls to restrict storage of sensitive information locally on mobile devices. It will also allow the company to remotely wipe any stolen mobile devices (Data Protection Commission, 2019).

References:

- Data Protection Commission (2018) Statement by Data Protection Commission in relation to Eir breach notification | 22/08/2018. Dublin: Data Protection Commission.
- Data Protection Commission (2019) General Portable Storage Device Recommendations. Dublin: Data Protection Commission.
- eircom Holdings (Ireland) Limited (2019) Annual Report for the Financial Year Ended 30 June 2019. Dublin: eircom Holdings (Ireland) Limited.